

Cyber Threat Analysis Report

1. Malware Sample Analysis

Analysis Platform: VirusTotal

The malware sample was analyzed using VirusTotal, as indicated by the screenshot showing a VirusTotal interface with a file hash (7a78e1...). Additionally, references to MalwareBazaar suggest the sample may have been sourced from this repository.

Detection Results

VirusTotal Findings: The file hash displayed in the VirusTotal interface suggests the sample was scanned, with results indicating potential malicious behavior based on detections from multiple antivirus engines. Specific detection ratios are not visible, but the presence of the hash implies a flagged file.

MalwareBazaar: The sample is likely cataloged in MalwareBazaar, a platform for sharing malware samples, indicating it is a known threat with documented characteristics.

Behavioral Indicators

The sample's behavior is not explicitly detailed in the images, but typical indicators for malware on VirusTotal include:

File Execution: Attempts to execute malicious code or payloads.

Network Activity: Communication with command-and-control (C2) servers.

Persistence: Registry modifications or scheduled tasks to maintain presence.

The presence of Metasploit-related tools in the images suggests the sample could be a payload delivered via exploits, potentially exhibiting behaviors like privilege escalation or lateral movement.

Potential Impact

Data Theft: Malware may exfiltrate sensitive information, such as credentials or personal data.

System Compromise: Potential for ransomware, spyware, or backdoor installation, leading to full system control by attackers.

Network Propagation: Risk of spreading to other systems within the network, especially if paired with exploits like those in Metasploit.

2. Phishing Template Creation Using Social Engineering Toolkit (SET) Environment

Operating System: Parrot OS

Tool: Social-Engineer Toolkit (SET) v8.0.3, as shown in the terminal screenshots.

Phishing Template Creation

The images demonstrate the use of SET's Credential Harvester Attack Method (option 3 in the web attack menu). The steps followed are:

Selection of Attack Vector:

From the SET web attack menu, option 3 (Credential Harvester Attack Method) was chosen, as seen in the terminal output (Page 7, Page 10).

This method captures credentials entered into a cloned or templated website.

Template Selection:

The user selected option 2 (Site Cloner) from the Credential Harvester menu, which clones a target website to create a phishing page (Page 7).
Site cloning allows attackers to replicate a legitimate website (e.g., a login page for Gmail or a corporate portal) to trick users into entering credentials.

Configuration:

The cloned website is hosted locally or on a server controlled by the attacker.
SET configures the phishing page to capture form inputs (username and password) and store them for the attacker.

Output

Phishing Page: A fully functional phishing page mimicking a legitimate website, designed to harvest credentials.
Risk: Users may unknowingly submit sensitive information, leading to account compromise or further exploitation.

Mitigation Recommendations

User Awareness: Educate users to verify website URLs and look for HTTPS.
Email Filtering: Deploy spam filters to block phishing emails linking to malicious sites.
MFA: Implement multi-factor authentication to reduce the impact of stolen credentials.

3. Mapping an APT Campaign to MITRE ATT&CK Framework

APT Campaign: APT29 (Cozy Bear)

APT29, a Russian state-sponsored group, is known for sophisticated cyberattacks targeting government and critical infrastructure. The campaign analyzed here aligns with their 2020 SolarWinds supply chain attack.

MITRE ATT&CK Mapping

Based on publicly available reports and the tools observed in the images (e.g., Metasploit, SET), the following ATT&CK techniques are mapped to APT29's tactics:

Initial Access (TA0001):

T1190 - Exploit Public-Facing Application: APT29 exploited vulnerabilities in SolarWinds Orion software to gain initial access, similar to Metasploit Browser Exploit methods shown in SET (Page 6).

T1566 - Phishing: Use of phishing campaigns to deliver malicious links or attachments, alignable with SET's Credential Harvester method.

Execution (TA0002):

T1059 - Command and Scripting Interpreter: Deployment of PowerShell scripts (akin to HTA Attack Method in SET) to execute malicious code.

Persistence (TA0003):

T1547 - Boot or Logon Autostart Execution: Malware installed via registry modifications to maintain persistence.

Privilege Escalation (TA0004):

T1068 - Exploitation for Privilege Escalation: Exploiting software vulnerabilities to gain higher privileges, similar to Metasploit exploits.

Defense Evasion (TA0005):

T1027 - Obfuscated Files or Information: Use of encoded payloads to evade detection, a common Metasploit technique.

Credential Access (TA0006):

T1555 - Credentials from Password Stores: Harvesting credentials via phishing pages, as demonstrated by SET's Credential Harvester.

Command and Control (TA0011):

T1071 - Application Layer Protocol: Communication with C2 servers over HTTPS, a behavior likely exhibited by the analyzed malware sample.

Impact

Data Breach: Exfiltration of sensitive government and corporate data.

Supply Chain Compromise: Widespread impact across multiple organizations due to trusted software exploitation.

Long-Term Access: Persistent access to networks for espionage.

Mitigation Recommendations

Patch Management: Regularly update software to close vulnerabilities.

Network Monitoring: Deploy intrusion detection systems to identify C2 traffic.

**Zero